Отчёт об исследовании инфраструктуры компании «ИнвестПро»

1. Сбор информации

Выделите в интервью любую важную, на ваш взгляд, информацию. Если удобно, можно оставлять комментарии.

Беседа с директором по инвестициям

В целом сам процесс проведения инвест-сессий не изменился. Но теперь мы публикуем на официальном сайте компании отчётность об их проведении и совершении некоторых сделок.

Своевременность и полноту публикуемых данных проверяет государственный регулятор, поэтому нам критически важно, чтобы эти данные всегда были доступны на сайте и не были искажены.

Беседа с техническим директором

Какие изменения? Недавно пришлось запустить свой веб-сервер. На сайте компании теперь нужно публиковать отчётность, а генеральный директор, как и в случае с ВКС, почему-то не доверяет облачным сервисам.

Кроме того, после того, как директор поставил задачу защитить ресурсы от различных атак, мы планируем развернуть WAF. Узнать, на какой стадии находится процесс его внедрения, можно у нашего главного администратора.

А ещё благодаря вашему отчёту руководству стало проще понять риски информационной безопасности, и мы кое-что улучшили. Во-первых, устранили ряд уязвимостей в версиях программного обеспечения. Во-вторых, максимально ограничили доступ в серверную. В-третьих, навели порядок в использовании носителей информации. И наконец, запретили в отделах подключать к сети личные сетевые устройства. Об этом тоже можно поспрашивать у администратора.

В перспективе планируем отказываться от использования облачных хранилищ. Сейчас их используем для обмена файлами по инвест-сессиям между

участниками, которые работают удалённо. Может быть, вместо хранилищ развернуть доступное из интернета файловое хранилище с защищённым подключением. Если на этот счёт есть какие-то мысли и предложения, буду благодарен.

Беседа с главным администратором

Изменений очень много! До сих пор как белка в колесе: устраняю недостатки в защите систем и вношу изменения в инфраструктуру. Предлагаю идти по пунктам:

- У нас появился собственный веб-сервер на базе **Nginx**. Для защиты планируем поднять **WAF**, но сервер для него ещё не приехал.

- Обновили версию **TrueConf** для устранения критической уязвимости и заодно версии установленных на нём утилит. Пофиксили уязвимость в программном обеспечении роутера **Cisco**, который стоял на входе в сеть. Теперь там используется свежая IOS.

  В других системах ничего не трогали, всё-таки сейчас все ресурсы направлены на изменение архитектуры сети. Не хочется параллельно поднимать сервисы, упавшие после обновлений. Надеюсь, доберёмся до этого процесса позже и сделаем его системным.

- Ещё перевели всех пользователей на **Linux**, так как у Windows 10 закончилась поддержка, а в Windows XP отпала необходимость — получилось отказаться от программ, которые работали только с этой ОС. Так сказать, решили проблему обновлений кардинально. Теперь сотрудники работают на **Ubuntu 22.04**. Иногда помогаем освоиться с новым интерфейсом, но постепенно все адаптируются.

- Доступ из интернета почти не изменился: как и раньше, сделан проброс портов для **почты**, **SSH** и **TrueConf**. Из нововведений — теперь доступен наш **веб-сайт**, а также появилась возможность подключиться по **RDP** к рабочим компьютерам пользователей. Мне кажется, это поможет с планом отказаться от хранения файлов в облаке: пользователь подключается к своему компьютеру, а дальше — к файловому серверу. Выглядит безопаснее, чем публиковать файловый сервер в интернет.

- Для почты стали использовать **Dovecot**, а файловый сервер тот же — **Samba** на ОС Ubuntu. До настройки специализированных решений по защите почты руки ещё не дошли. Права доступа предоставляем как и раньше — настраиваем по звонку.

- Ещё в серверную так доступ ограничили, что мышь не проскользнёт. И убрали ненужный роутер в отделе инвестиций. Руководство выделило деньги на резервный канал. Говорят, на следующей неделе заключим договор с новым провайдером. Жду не дождусь, когда заведут линию от нового провайдера.

2. Анализ защищённости инфраструктуры

Сеть компании

1. Проблемы в безопасности архитектуры сети компании:

- Нет DMZ
- WAF. Везут сервер, пока все еще актуально.
- ВКС интегрирована с электронной почтой, почтовый сервер доступен извне - фишинг через почту.
- Резервный канал интернета сделают на следующей неделе. Значит все еще актуально
- Нет централизованного управления серверами.
- Нет шифрования данных

Из предыдущих уязвимостей, не было информации об исправлении, считаю уязвимости актуальными

- Логины и пароли оставляют на виду, так же как и токены в коробке
- Нет бэкапов
- Файловый сервер без достаточного объема памяти.
- Почта без анти-спам модуля.
- Недостаточное охлаждение серверной. .

2. Сервисы, доступные из сети Интернет:

Заполните таблицу с доступными сервисами.

Название сервиса	**Номер порта**
SSH	22/2222

SMTP	25
WebSite	80
RDP	3389
TrueConf	8000

3. Сведения о сервисах и открытых портах внутри сети компании:

Заполните таблицу по аналогии с примером в первой строке.

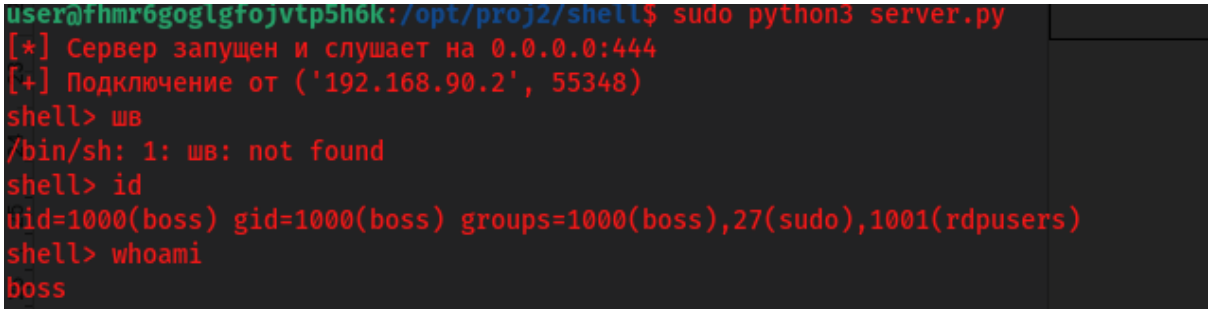
Хост	IP-адрес	Название сервиса	Номер порта
srv_web	192.168.50.10	Alpine linux, nginx-1.26.3-r0	80
srv_mail	192.168.50.20	Dovecot 1:2.3.19.1, Debian Ubuntu	25
srv_truconf	192.168.50.50	trueconf-server 5.5.4.10145-deb12 amd64	8000
srv_fs	192.168.50.30	samba 2:4.15.13+dfsg-0ubuntu1.12 amd64	445
srv_dns	192.168.50.70	DNS	53

Эндпоинты и сервисы

1. Сведения об эндпоинтах и сервисах в сети компании:

Хост	IP-адрес	Название и версия ОС	Название и версия прикладного сервиса
user-go-boss	192.168.0.100	Ubuntu 22.04	Не очень понимаю что имеется ввиду, на клиентах установлен классический пак инструментов ubuntu или Alpine(что кстати странно, потому что в риск-сессии говорили что у всех убунту), на десктопе у всех установлен почтовый клиент Mozilla ThunderBird, у которого есть уязвимости.(CVE-2015-2740, CVE-2023-28163)
user-go-lebed	192.168.0.10	Alpine Linux v3.20	
user-go-solov	192.168.0.20	Alpine Linux v3.20	
admin-go-pc	192.168.0.50	Ubuntu 22.04	

2. Укажите пользователя, который не соблюдает правила безопасной работы с входящими письмами.



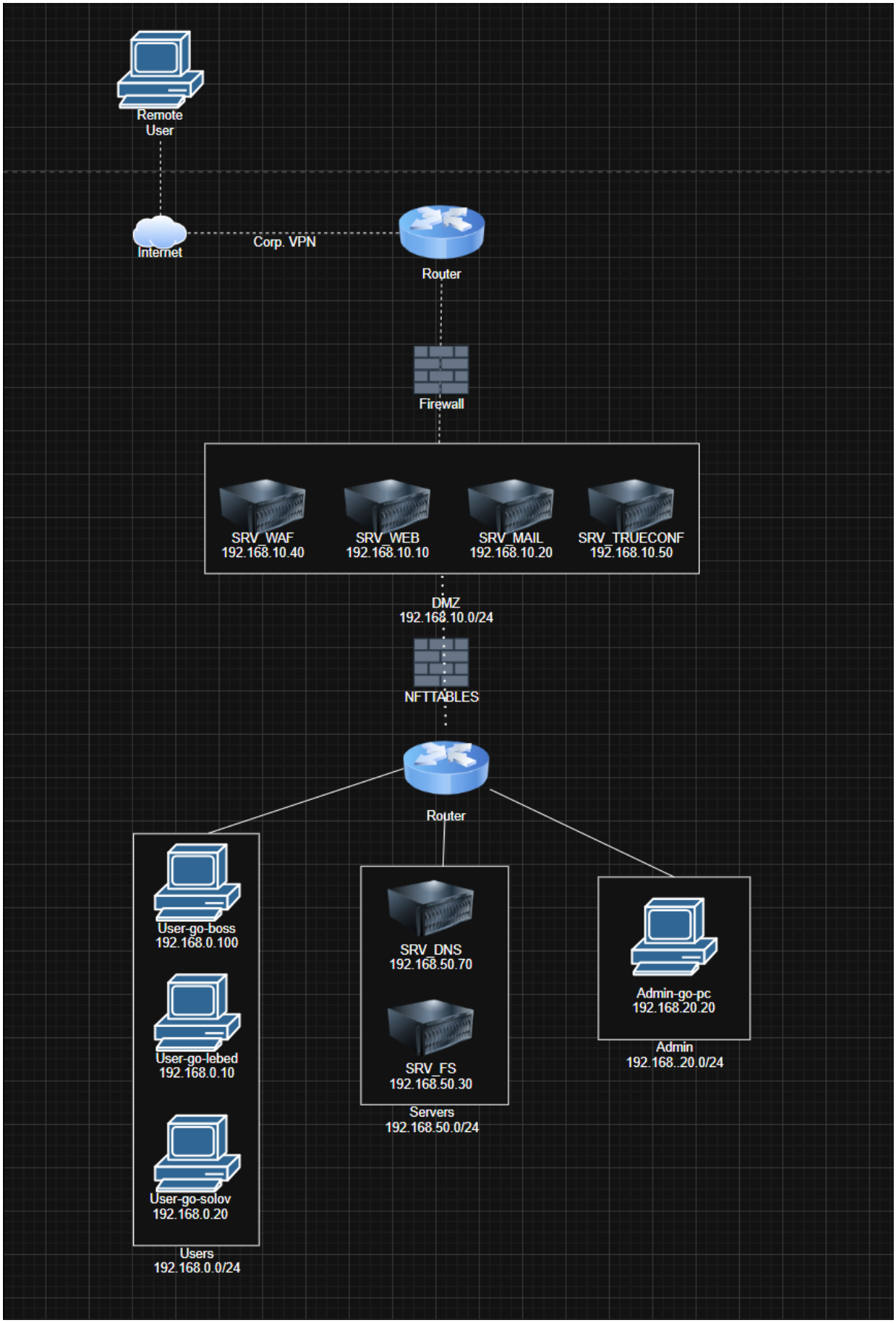
Пользователь: boss

3. Уточнение модели угроз и подготовка предложений по защите инфраструктуры

Модель угроз и оценка рисков InvestPro v.2.xlsx

Целевая схема сети компании

1. Обновлённая схема сети компании:


Remote
User
Internet
Corp. VPN
Router
Firewall
SRV_WAF
192.168.10.40
SRV_WEB
192.168.10.10
SRV_MAIL
192.168.10.20
SRV_TRUECONF
192.168.10.50
DMZ
192.168.10.0/24
NFTTABLES
Router
User-go-boss
192.168.0.100
User-go-lebed
192.168.0.10
User-go-solov
192.168.0.20
Users
192.168.0.0/24
SRV_DNS
192.168.50.70
SRV_FS
192.168.50.30
Servers
192.168.50.0/24
Admin-go-pc
192.168.20.20
Admin
192.168..20.0/24

2. Таблица необходимых сетевых потоков для новой схемы сети:

Описание потока	Исходящий /входящий	Откуда (IP-адрес/подсеть)	Куда (IP-адрес/подсеть)	Порты и протоколы
Электронная почта				
Получение почты	Входящий	Любой	SRV MAIL (192.168.10.20)	SMTP 25
Получение почты (IMAP)	Исходящий	Users (192.168.0.0/24)	SRV MAIL (192.168.10.20)	IMAP 143
Отправка почты	Исходящий	Users (192.168.0.0/24)	SRV MAIL (192.168.10.20)	SMTP 587
Администрирование	Исходящий	Admin (192.168.20.0/24)	SRV MAIL (192.168.10.20)	SSH 22
Веб-сервер				
Из интернета	Входящий	Internet (любой)	SRV WEB (192.168.10.10)	HTTP(S) 80/443
Юзеры к веб-сайту	Исходящий	Users (192.168.0.0/24)	SRV WEB (192.168.10.10)	HTTP(S) 80/443
Администрирование	Исходящий	Admin (192.168.20.0/24)	SRV WEB (192.168.10.10)	SSH 22
Выход в интернет	Исходящий	SRV WEB (192.168.10.10)	Internet	HTTP(S) 80/443
WAF				
к ВЕБу	Исходящий	SRV WAF (192.168.10.40)	SRV WEB (192.168.10.10)	HTTP(S) 80/443
Администрирование	Исходящий	Admin (192.168.20.0/24)	SRV WAF (192.168.10.40)	SSH 22
DNS				
DNS-запрос	Исходящий	Users (192.168.0.0/24)	SRV DNS (192.168.50.70)	DNS 53
DNS-запрос	Исходящий	DMZ (192.168.10.0/24)	SRV DNS (192.168.50.70)	DNS 53
DNS-запрос	Исходящий	Admin (192.168.20.0/24)	SRV DNS (192.168.50.70)	DNS 53
В интернет	Исходящий	SRV DNS (192.168.50.70)	Internet (любой)	DNS 53
Администрирование	Исходящий	Admin (192.168.20.0/24)	SRV DNS (192.168.50.70)	SSH 22
Файловый сервер				
Доступ к файлам	Исходящий	Users (192.168.0.0/24)	SRV FS (192.168.50.30)	SMB 139, 445
Доступ к файлам	Исходящий	Admin (192.168.20.0/24)	SRV FS (192.168.50.30)	SMB 139, 445

Администрирование	Исходящий	Admin (192.168.20.0/24)	SRV FS (192.168.50.30)	SSH 22
Users				
Выход в интернет	Исходящий	Users (192.168.0.0/24)	Internet (любой)	HTTP(S) 80/443
Admin				
Выход в интернет	Исходящий	Admin (192.168.20.0/24)	Internet (любой)	HTTP(S) 80/443
SSH-доступ ко всем серверам	Исходящий	Admin (192.168.20.0/24)	Все серверы (DMZ и Servers)	SSH 22
Общие				
Подключение к рабочей станции	Входящий	Удаленный пользователь	Users (192.168.0.0/24)	SSH 22

Комментарии

Здесь вы можете оставить любые комментарии для ревьюера.